

Security+ 2.1 · Threat Actors

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.1 — Threat Actors (10:23)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Quem ataca e POR QUÊ: nation-state (governo — espionagem/sabotagem, recursos enorme — APT); organized crime (lucro — ransomware, credential theft); hacktivist (ideologia — Anonymous); insider (dentro da casa — intencional ou descuidado); script kiddie (usa exploit pronto, volume); shadow IT (aplicação não-oficial que vira porta de entrada); competidor (industrial espionage).

💡 Highlights que a prova cobra

- APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo
- Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar
- Script kiddie: usa exploit pronto — volume, pouca sofisticação
- Insider: o maior risco por já estar DENTRO da confiança

🎯 Dicas de prova & Cenários Típicos

- 'motivated by political/social ideology' = hacktivist
- 'long-term, nation-state, persistent' = APT

Cenário clássico de exame: Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.1 — Threat Actors)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?

- A)** Firewall mal configurado
- B)** Phishing + VPN sem MFA / credencial vazada
- C)** Cabo de rede exposto
- D)** Falta de antivírus

3. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

4. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: APT (Advanced Persistent Threat): government-backed — recursos enormes, tar...

5. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Organized crime = dinheiro; hacktivist = ideologia; nation-state = política...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Script kiddie: usa exploit pronto — volume, pouca sofisticação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Script kiddie: usa exploit pronto — volume, pouca sofisticação...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Insider: o maior risco por já estar DENTRO da confiança'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Insider: o maior risco por já estar DENTRO da confiança...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'motivated by political/social ideology' = hacktivist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'motivated by political/social ideology' = hacktivist...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'long-term, nation-state, persistent' = APT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'long-term, nation-state, persistent' = APT...

10. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário típico: 'um grupo financiado por governo espiona infra-critical por...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — BEC / CEO fraud (fraude do CEO).

✓ **Por que está certa:** A alternativa correta é 'BEC / CEO fraud (fraude do CEO)'. Business Email Compromise (BEC) é uma categoria de ataque de engenharia social em que o atacante se passa por um executivo de alto escalão (como o CEO) ou por um parceiro de negócios confiável para induzir funcionários a realizar transferências financeiras não autorizadas ou divulgar informações confidenciais. No caso descrito, o golpista envia um e-mail fraudulento se passando pelo CEO e ordena uma transferência urgente ao setor financeiro. Isso se enquadra perfeitamente na definição de BEC, que é reconhecida pela CompTIA como um vetor de ataque baseado em impersonação e engenharia social. A variante específica em que o CEO é personificado é chamada de CEO fraud. Portanto, a opção 'BEC / CEO fraud (fraude do CEO)' é a que melhor descreve o ataque.

✗ **Por que as outras estão erradas:**

- *Whaling*: Whaling é um tipo de ataque de phishing direcionado especificamente a executivos de alto nível (como CEOs, CFOs, etc.). O objetivo é obter informações confidenciais ou acesso a sistemas críticos por meio de e-mails fraudulentos que se passam por fontes confiáveis. No entanto, no cenário descrito, o atacante não está mirando o CEO, mas sim se passando por ele para enganar o setor financeiro. Portanto, whaling não é o termo correto, pois descreve o alvo (o executivo) e não o modus operandi de impersonação do CEO para fraudar subordinados.
- *Vishing*: Vishing é a prática de engenharia social realizada por meio de chamadas telefônicas (voice phishing), onde o atacante se passa por uma entidade confiável para obter informações sensíveis, como senhas ou dados financeiros. No enunciado, o ataque ocorre por e-mail, não por telefone. Portanto, vishing não se aplica ao canal utilizado. Além disso, o vishing não envolve necessariamente a personificação do CEO para ordenar transferências, mas sim ligações fraudulentas em geral.
- *Tailgating*: Tailgating é uma técnica de acesso físico não autorizado em que uma pessoa segue outra em uma área restrita sem se autenticar, geralmente explorando a cortesia ou distração do funcionário autorizado. Não tem relação com ataques de engenharia social por e-mail ou fraudes financeiras. O cenário descreve um ataque cibernético baseado em e-mail fraudulento, não uma invasão física. Portanto, tailgating é completamente inadequado para a situação.

2) B — Phishing + VPN sem MFA / credencial vazada.

✓ **Por que está certa:** A alternativa correta é: Phishing + VPN sem MFA / credencial vazada. No domínio de Ameaças, Vulnerabilidades e Mitigações da CompTIA Security+ SY0-701, o ransomware moderno (como operações de Ransomware-as-a-Service) utiliza táticas de acesso inicial que exploram o fator humano e configurações inadequadas de autenticação. O phishing continua sendo o vetor mais prevalente: e-mails maliciosos, mensagens em redes sociais ou sites falsos induzem o usuário a entregar credenciais ou executar cargas maliciosas. Além disso, VPNs sem MFA (autenticação multifator) permitem que credenciais vazadas em vazamentos de dados ou compradas em mercados clandestinos sejam usadas diretamente para acesso remoto à rede corporativa. A combinação de phishing para obter credenciais e a ausência de MFA em VPNs é uma das falhas mais exploradas, pois contorna perímetros tradicionais e dá ao atacante acesso legítimo à rede. A CompTIA enfatiza que a implementação de MFA é uma mitigação crítica contra esse vetor.

✗ **Por que as outras estão erradas:**

- *Firewall mal configurado*: Um firewall mal configurado pode permitir tráfego não autorizado, mas não é o vetor de acesso inicial mais explorado em ransomware moderno. Firewalls tradicionais atuam na camada de rede e, quando bem configurados, bloqueiam portas e serviços expostos. No

entanto, ataques modernos frequentemente usam credenciais válidas obtidas por phishing ou vazamento, o que faz com que o tráfego pareça legítimo e não seja bloqueado por regras de firewall. Além disso, a exploração de firewall geralmente requer vulnerabilidades específicas ou erros graves de configuração, menos comuns do que o comprometimento de credenciais. Portanto, não é a falha mais explorada.

- *Cabo de rede exposto*: Um cabo de rede exposto é uma vulnerabilidade física que permite a um atacante com acesso local conectar-se à rede. Embora seja um risco em ambientes com controle de acesso físico deficiente, não é um vetor típico de acesso inicial para ransomware moderno, que geralmente é executado remotamente por meio de phishing, exploração de serviços expostos ou credenciais comprometidas. Ataques físicos exigem proximidade e podem ser mitigados com segurança física, mas não representam a principal porta de entrada para campanhas de ransomware em larga escala.
- *Falta de antivírus*: A ausência de antivírus é uma deficiência de controle, mas não é o vetor de acesso inicial mais explorado. Antivírus modernos são eficazes contra malware conhecido, mas ransomware sofisticado frequentemente usa técnicas de evasão (ofuscação, fileless, living-off-the-land) que podem contornar soluções baseadas em assinaturas. Além disso, o acesso inicial ocorre antes da execução do ransomware, por meio de credenciais comprometidas ou phishing. A falta de antivírus agrava o impacto, mas não é a falha primária que permite a entrada do atacante. A CompTIA destaca que a conscientização e o MFA são mais críticos para prevenir o acesso inicial.

3) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** O NIST Cybersecurity Framework (CSF) 2.0 organiza as atividades de segurança cibernética em cinco funções principais: Identificar, Proteger, Detectar, Responder e Recuperar. Essas funções representam o ciclo de vida completo da gestão de riscos cibernéticos. 'Identificar' envolve entender o contexto organizacional, ativos, riscos e vulnerabilidades. 'Proteger' abrange a implementação de salvaguardas para garantir a entrega de serviços críticos. 'Detectar' define as atividades para identificar a ocorrência de eventos de segurança cibernética. 'Responder' compreende as ações tomadas após a detecção de um incidente. 'Recuperar' foca na restauração de capacidades ou serviços que foram prejudicados. Essa estrutura é amplamente adotada e exigida no domínio de Arquitetura e Design de Segurança da certificação CompTIA Security+ (SY0-701), especificamente no objetivo 2.1, que trata de frameworks e diretrizes.

✗ **Por que as outras estão erradas:**

- *Instalar, Atualizar, Testar, Auditar, Arquivar*: Esses termos descrevem etapas genéricas de um processo operacional de TI, como um ciclo de vida de software ou de gestão de patches, mas não constituem as funções do NIST CSF. 'Instalar' e 'Atualizar' referem-se à implantação e manutenção de sistemas; 'Testar' é uma atividade de verificação; 'Auditar' é uma avaliação de conformidade; e 'Arquivar' é uma prática de retenção de dados. Nenhuma dessas ações corresponde às funções estratégicas de alto nível definidas pelo NIST CSF, que são orientadas a riscos e não a tarefas táticas.
- *Planejar, Fazer, Checar, Agir, Revisar*: Essa é uma variação do ciclo PDCA (Plan-Do-Check-Act), utilizado em sistemas de gestão da qualidade e melhoria contínua, como a ISO 9001. Embora o NIST CSF possa ser integrado a processos de melhoria contínua, suas cinco funções não são 'Planejar, Fazer, Checar, Agir, Revisar'. O PDCA é um modelo genérico de gestão, enquanto as funções do CSF são específicas para segurança cibernética e possuem escopo e definições próprias. A inclusão de 'Revisar' como quinta etapa é uma distorção, pois o PDCA clássico tem quatro etapas.
- *Prevenir, Punir, Prever, Provar, Publicar*: Esses termos não fazem parte de nenhum framework reconhecido de segurança cibernética. 'Prevenir' é um objetivo, mas não uma função do CSF; 'Punir' é uma ação disciplinar ou legal, não uma função de segurança; 'Prever' é uma meta

aspiracional, não uma função operacional; 'Provar' e 'Publicar' são ações de auditoria e comunicação, respectivamente, mas não compõem a estrutura do NIST CSF. Essa alternativa mistura conceitos de justiça, previsão e divulgação, sem qualquer relação com as funções oficiais do framework.

4) D — Implementar a solução correspondente: APT (Advanced Persistent Threat): government-backed — recursos enormes, tar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: Organized crime = dinheiro; hacktivist = ideologia; nation-state = política....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Script kiddie: usa exploit pronto — volume, pouca sofisticação....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Script kiddie: usa exploit pronto — volume, pouca sofisticação.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Insider: o maior risco por já estar DENTRO da confiança....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Insider: o maior risco por já estar DENTRO da confiança.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: 'motivated by political/social ideology' = hacktivist....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): 'motivated by political/social ideology' = hacktivist.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'long-term, nation-state, persistent' = APT....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): 'long-term, nation-state, persistent' = APT.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Cenário típico: 'um grupo financiado por governo espiona infra-critical por....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.